6

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad / Öğrenci No
Mehmet Emin Yılmaz · No: 235541078

Grup
Gece B

Senaryo: Saat **10:15**. J-500'ün servis/uzak bakım hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. Mazatrol CNC programları/parametreleri değişmiş olabilir; **kapı kilidi ve E-stop fonksiyonları henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?**
   Aranacaklar: üretim/bakım müdürü, iş güvenliği (emniyet) sorumlusu, IT/OT güvenlik sorumlusu, Mazak yetkili servisi; olay yöneticisi/uyum sorumlusu (bildirim saatini başlatmak için). **İlk üç eylem:** (1) Operatörü makineden uzaklaştırıp makineyi **kontrollü durdurmak** (kapıyı açmadan, enerjiyi kesmeden, resetlemeden); (2) **uzak erişim yolunu kesmek** (uzak bakım modülünü/ağ bağlantısını fiziksel izole etmek); (3) saati, ekranı ve konuşulanları **kayda geçirmek** (fotoğraf, olay defteri).

2. **İlk 2 saat: Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?**
   Doğrulama: makine kilitleme (LOTO) altında, yetkili kişiyle Emniyet PLC konfigürasyonu bilinen-iyi yedekle karşılaştırılır (sürüm, parametre, sağlama toplamı); kapı kilidi, E-stop, onay şalteri, hız limiti ve STO fonksiyon testleri yapılır; geçmeden üretime dönülmez. **Kanıt:** uzak bakım/VPN/güvenlik duvarı ve oturum logları, CNC alarm ve operasyon geçmişi, program/parametre değişim kayıtları, değişmiş konfigürasyonun adli kopyası (hash'li). **Hesap:** ele geçirilen servis hesabı ve aynı parolayı paylaşan hesaplar (admin/admin) devre dışı bırakılır (silinmez), parolalar yenilenir.

3. **24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?**
   Olayın ne zaman, nasıl fark edildiği; etkilenen ürün/model, seri numarası ve yazılım/firmware sürümü; kötü niyetli eylem şüphesi (evet/şüpheli); ilk etki değerlendirmesi (emniyet fonksiyonu etkilendi mi, yaralanma var mı); alınan acil önlemler ve irtibat kişisi. *Yükümlülüğün kime ait olduğu (üretici/işletici) uyum birimiyle netleştirilir.*

4. **72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?**
   Kök neden (IT/OT güvenlik, log analizi): paylaşılan servis hesabı + internete açık uzak bakım hipotezi doğrulanır. **Etki** (bakım + Mazak servisi + kalite): hangi program/parametre değişti, emniyet etkilendi mi, etkilenen parçalar/partiler (izlenebilirlik). **Önlem:** erişim kapatıldı, parolalar yenilendi, jump server/VPN/MFA ve segmentasyon planı. Vardiya sorumlusu olay kaydını tutar; bildirimi yetkili uyum sorumlusu onaylayıp gönderir.

5. **14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?**
   Uzak bakım/VPN/jump server oturum kayıtları, kimlik doğrulama ve güvenlik duvarı logları, ağ trafik kaydı, Mazatrol alarm ve operasyon geçmişi, program ve parametre değişim geçmişi, Emniyet PLC doğrulama test raporları, yedek/geri yükleme kayıtları, kanıt zinciri (kim aldı, hash), alınan düzeltici aksiyonlar. Loglar değiştirilemez ortamda saklanır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur. *Not: Mimari ayrıntılar eğitim amaçlı varsayımdır; üretici dokümanıyla doğrulanmalıdır.*